



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report

Sites: <https://fastapi.tiangolo.com> <https://cdn.jsdelivr.net> <http://127.0.0.1:8000>

Generated on Sat, 26 Sept 2026 09:51:43

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	1
Medium	3
Low	2
Informational	4

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap. log file for details	2
Info	Informational	http://127.0.0.1:8000	Percentage of responses with status code 2xx	85 %
Info	Informational	http://127.0.0.1:8000	Percentage of responses with status code 4xx	14 %
Info	Informational	http://127.0.0.1:8000	Percentage of endpoints with content type application/json	85 %
Info	Informational	http://127.0.0.1:8000	Percentage of endpoints with content	14 %

			type text /html	
Info	Informational	http://127.0.0.1:8000	Percentage of endpoints with method GET	57 %
Info	Informational	http://127.0.0.1:8000	Percentage of endpoints with method POST	42 %
Info	Informational	http://127.0.0.1:8000	Count of total endpoints	7
Info	Informational	http://127.0.0.1:8000	Percentage of slow responses	28 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of responses with status code 2xx	100 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with content type application /javascript	50 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with content type text /css	50 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with method GET	100 %
Info	Informational	https://cdn.jsdelivr.net	Count of total endpoints	2
Info	Informational	https://cdn.jsdelivr.net	Percentage of slow responses	50 %
Info	Informational	https://fastapi.tiangolo.com	Percentage of responses with status code 2xx	100 %
Info	Informational		Percentage of endpoints with	100 %

		https://fastapi.tiangolo.com	content type image /png	
Info	Informational	https://fastapi.tiangolo.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://fastapi.tiangolo.com	Count of total endpoints	1

Alerts

Name	Risk Level	Number of Instances
Authentication Credentials Captured	High	1
Content Security Policy (CSP) Header Not Set	Medium	1
Cross-Domain Misconfiguration	Medium	2
Sub Resource Integrity Attribute Missing	Medium	2
Cross-Domain JavaScript Source File Inclusion	Low	1
Timestamp Disclosure - Unix	Low	Systemic
Authentication Request Identified	Informational	2
Modern Web Application	Informational	1
Retrieved from Cache	Informational	2
Session Management Response Identified	Informational	1

Alert Detail

High	Authentication Credentials Captured
Description	An insecure authentication mechanism is in use. This allows an attacker on the network access to the userid and password of the authenticated user. For Basic Authentication, the attacker must merely monitor the network traffic until a Basic Authentication request is received, and then base64 decode the username and password. For Digest Authentication, the attacker has access to the username, and possibly also the password, if the hash (including a nonce) can be successfully cracked, or if a Man-In-The-Middle attack is mounted. The attacker eavesdrops on the network until an authentication has completed.
URL	http://127.0.0.1:8000/auth/token
Node Name	http://127.0.0.1:8000/auth/token ()(grant_type,password,username)
Method	POST
Attack	
Evidence	
Other Info	[POST] [http://127.0.0.1:8000/auth/token] uses insecure authentication mechanism [Basic], revealing username [] and password [].
Instances	1

Solution	Use HTTPS, and use a secure authentication mechanism that does not transmit the userid or password in an un-encrypted fashion. In particular, avoid use of the Basic Authentication mechanism, since this trivial obfuscation mechanism is easily broken.
Reference	https://owasp.org/www-community/attacks/Brute_force_attack https://en.wikipedia.org/wiki/Digest_access_authentication
CWE Id	287
WASC Id	1
Plugin Id	10105

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://127.0.0.1:8000/docs
Node Name	http://127.0.0.1:8000/docs
Method	GET
Attack	
Evidence	
Other Info	
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Cross-Domain Misconfiguration
Description	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Method	GET
Attack	
Evidence	access-control-allow-origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could

	be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui.css
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui.css
Method	GET
Attack	
Evidence	access-control-allow-origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
Instances	2
Solution	Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.
Reference	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
CWE Id	264
WASC Id	14
Plugin Id	10098

Medium	Sub Resource Integrity Attribute Missing
Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	http://127.0.0.1:8000/docs
Node Name	http://127.0.0.1:8000/docs
Method	GET
Attack	
Evidence	<link type="text/css" rel="stylesheet" href="https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui.css">
Other Info	
URL	http://127.0.0.1:8000/docs
Node Name	http://127.0.0.1:8000/docs
Method	GET
Attack	
Evidence	<script src="https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js"></script>
Other Info	
Instances	2
Solution	Provide a valid integrity attribute to the tag.

Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003

Low	Cross-Domain JavaScript Source File Inclusion
Description	The page includes one or more script files from a third-party domain.
URL	http://127.0.0.1:8000/docs
Node Name	http://127.0.0.1:8000/docs
Method	GET
Attack	
Evidence	<script src="https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js"></script>
Other Info	
Instances	1
Solution	Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.
Reference	
CWE Id	829
WASC Id	15
Plugin Id	10017

Low	Timestamp Disclosure - Unix
Description	A timestamp was disclosed by the application/web server. - Unix
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Method	GET
Attack	
Evidence	1518500249
Other Info	1518500249, which evaluates to: 2018-02-13 16:37:29.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Method	GET
Attack	
Evidence	1732584193
Other Info	1732584193, which evaluates to: 2024-11-26 12:23:13.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Method	GET
Attack	

Evidence	1750603025
Other Info	1750603025, which evaluates to: 2025-06-23 00:37:05.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Method	GET
Attack	
Evidence	1859775393
Other Info	1859775393, which evaluates to: 2028-12-07 15:16:33.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Method	GET
Attack	
Evidence	1894007588
Other Info	1894007588, which evaluates to: 2030-01-07 20:13:08.
Instances	Systemic
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	http://127.0.0.1:8000/auth/token
Node Name	http://127.0.0.1:8000/auth/token ()(client_id,client_secret,grant_type,password,scope,username)
Method	POST
Attack	
Evidence	password
Other Info	userParam=username userValue=admin passwordParam=password
URL	http://127.0.0.1:8000/auth/token
Node Name	http://127.0.0.1:8000/auth/token ()(grant_type,password,username)
Method	POST
Attack	

Evidence	password
Other Info	userParam=username userValue=admin passwordParam=password
Instances	2
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.
URL	http://127.0.0.1:8000/docs
Node Name	http://127.0.0.1:8000/docs
Method	GET
Attack	
Evidence	<script src="https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	1
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Retrieved from Cache
Description	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Method	GET
Attack	
Evidence	HIT
Other Info	
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui.css
Node	

Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui.css
Method	GET
Attack	
Evidence	HIT
Other Info	
Instances	2
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.rfc-editor.org/rfc/rfc9110.html
CWE Id	525
WASC Id	
Plugin Id	10050

Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	http://127.0.0.1:8000/auth/token
Node Name	http://127.0.0.1:8000/auth/token ()(grant_type,password,username)
Method	POST
Attack	
Evidence	access_token
Other Info	json:access_token
Instances	1
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112